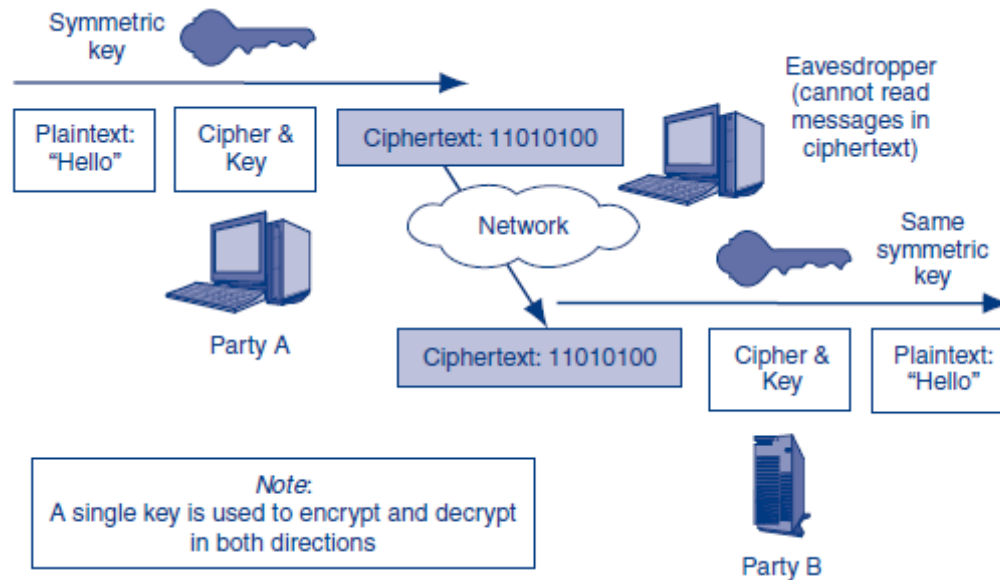


Bilgisayar ve Ağ Güvenliği

Kriptoloji

Kriptoloji Nedir ?

- Kriptografi, taraflar arasında gönderilen/alınan veya bir bilgisayarda saklanan mesajları korumak için matematiksel işlemlerin kullanılmasıdır.
- Kriptografinin ilk amacı gizliliktir.



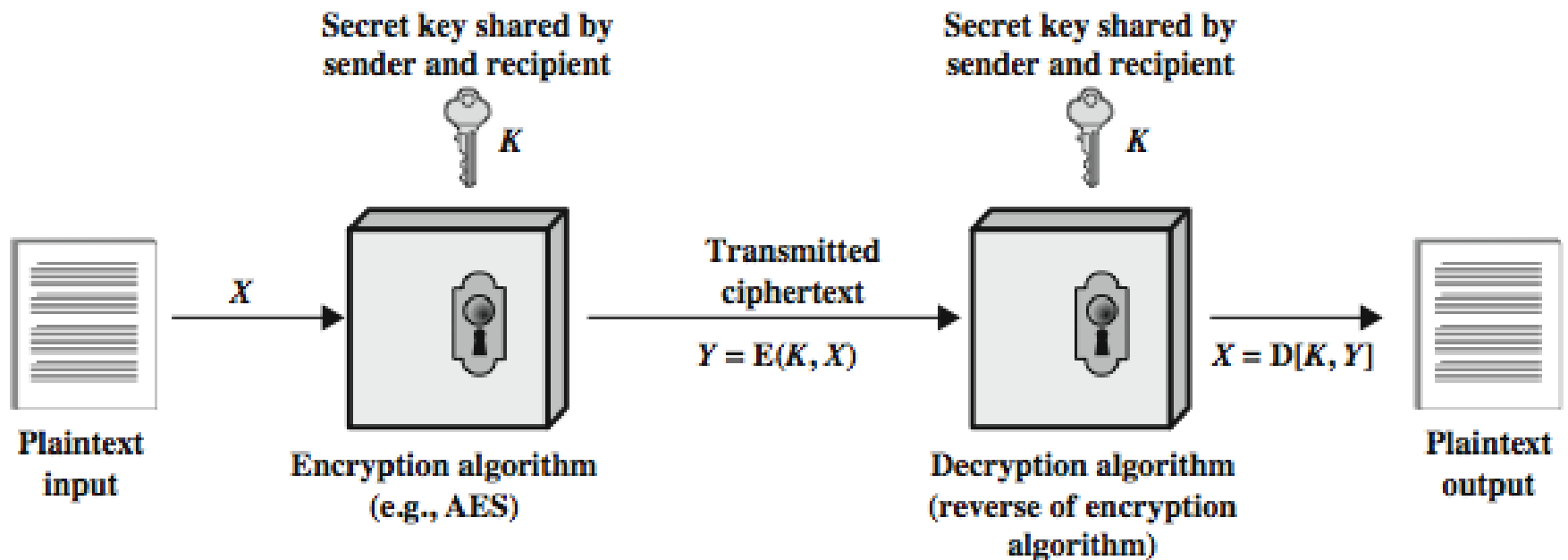
Terminoloji

- **plaintext** – orijinal mesaj
- **ciphertext** – kodlanmış mesaj
- **cipher** – plaintexti ciphertext'e dönüştüren algoritma
- **key** – sadece alıcı/vericide bilinen cipherda kullanılan bilgi
- **encipher (encrypt)** – plaintextin ciphera dönüşümü
- **decipher (decrypt)** - plaintextden ciphertexti- kurtarma
- **kriptografi** - şifreleme ilkelerinin / yöntemlerinin incelenmesi
- **kriptoanaliz (codebreaking)** - anahtar bilmeden ciphertext çözme ilkeleri / yöntemlerinin incelenmesi
- **kriptoloji** – kriptografi ve kriptoanaliz alanı

Simetrik Şifreleme

- Geleneksel / private-key / single-key
- Gönderici ve alıcı ortak bir anahtarı paylaşır
- Tüm klasik şifreleme algoritmaları özel anahtardır.
- 1970 lerde public keylerden önceki türdü.
- En çok kullanılan yapıdır.

Simetrik Şifreleme Modeli



Gereksinimler

- Simetrik şiflemenin güvenli kullanımı için iki gereksinimi:
 - Güçlü bir şifreleme Algoritması
 - Alıcı ve gönderici tarafından bilinen güvenli bir anahtar (key)
- Matematiksel olarak:
$$Y = E(K, X)$$
$$X = D(K, Y)$$
- Şifreleme algoritmasının bilindiği varsayılırsa
- Dağıtık bir güvenli kanalın oluşturulması gerekir.

Kriptografi

- Kriptografik sistemi şöyle karakterize edebilir:
 - kullanılan şifreleme işlemlerinin türü
 - Kaydırma (substitution)
 - Transpoz (transposition)
 - Ürün (product)
 - kullanılan key sayısı
 - tek anahtar veya özel (private)
 - iki anahtar veya genel (public)
 - düz metnin işlendiği yol
 - blok
 - Akış (stream)

Basit Bir Örnek

Plaintext	Key	Ciphertext
n	4	r
o	8	w
w	15	l
i	16	...
s	23	...
t	16	...
h	3	...
e	9	...
t	12	...
i	20	...
m	6	...
e	25	...

Key (Part 2)	Key (Part 1)		
	1	3	2
2	n	o	w
3	i	s	t
1	h	e	t

Kriptoanaliz

- Tipik olarak amaç, tek bir şifreli metnin düz metnini kurtarmak için basitçe kullanımdaki anahtarı kurtarmaktır.

İki genel yaklaşım vardır:

- Kriptanalitik Saldırıları: algoritmanın doğasına ve belki de düz metnin genel özelliklerine ve hatta bazı örnek düz metin-şifreli metin çiftlerine ait bazı bilgilere dayanır. Bu tür bir saldırı, belirli bir düz metnin çıkarılması veya kullanılan anahtarın çıkarılması amacıyla algoritmanın özelliklerini kullanır.
- Brute-force saldırıları, düz metne dönüştürülebilir bir çeviri elde edilinceye kadar, şifreli bir parçadaki olası tüm anahtarları dener. Ortalama olarak, başarmak için tüm olası anahtarların yarısı denenmelidir.
- Herhangi bir saldırı türü anahtarı çıkarmada başarılı olursa, etki felakettir: Bu anahtarla şifrelenen gelecekteki ve geçmiş iletiler ele geçirilir.

Anahtar Uzunluğu

Key Length In Bits	Number of Possible Keys
1	2
2	4
4	16
8	256
16	65,536
40	1,099,511,627,776
56	72,057,594,037,927,900
112	5,192,296,858,534,830,000,000,000,000,000
112	5.1923E+33
168	3.74144E+50
256	1.15792E+77
512	1.3408E+154

Notlar: Anahtarın bir bitini eklemek, bir kriptanalistin anahtarı kırmak için harcadacağı süreyi iki katına çıkarır. 100 bit veya daha fazla uzunluktaki gizli anahtarlar, günümüzde güçlü simetrik anahtarlar olarak kabul edilir.

100 bitten daha kısa olan anahtarlar, bugün zayıf simetrik anahtar olarak kabul edilir. Özel anahtarın kırılması ve özel anahtarların sık sık değiştirilememesi nedeniyle, genel anahtar / özel anahtar çiftleri (daha sonra ele alınacak) çok daha güçlüdür. Ortak anahtarlar ve özel anahtarlar en az 512 ila 1.024 bit uzunluğunda olmalıdır.

Brute Force Arama

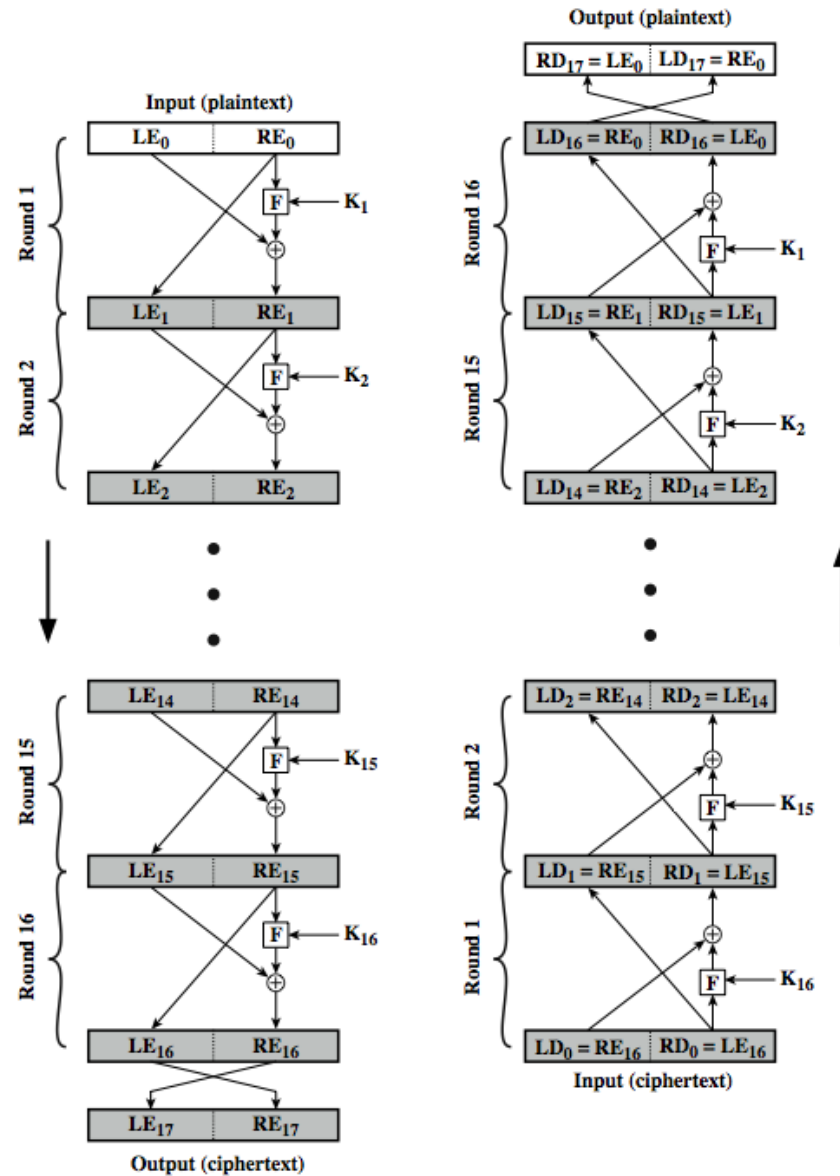
- Her anahtar basitçe denenerek yapılan saldırıdır.
- Anahtar boyutuyla orantılı en temel saldırı
- Planitext biliniyorsa veya tanınıyorsa

Key Size (bits)	Number of Alternative Keys	Time required at 1 decryption/ μ s	Time required at 10^6 decryptions/ μ s
32	$2^{32} = 4.3 \times 10^9$	$2^{31} \mu$ s = 35.8 minutes	2.15 milliseconds
56	$2^{56} = 7.2 \times 10^{16}$	$2^{55} \mu$ s = 1142 years	10.01 hours
128	$2^{128} = 3.4 \times 10^{38}$	$2^{127} \mu$ s = 5.4×10^{24} years	5.4×10^{18} years
168	$2^{168} = 3.7 \times 10^{50}$	$2^{167} \mu$ s = 5.9×10^{36} years	5.9×10^{30} years
26 characters (permutation)	$26! = 4 \times 10^{26}$	$2 \times 10^{26} \mu$ s = 6.4×10^{12} years	6.4×10^6 years

Feistel Cipher Structure

- **feistel cipher**, Horst Feistel tarafından geliştirilmiştir.
 - Ters ürün şifrelemeye uygun
- Giriş bloğu iki parçaya ayrılır.
 - Birden fazla tur boyunca işlem
 - Sol yarı veride kaydırma yap
 - Sağ yarı veya alt anahtarın döndürme fonksiyonuna dayalı
 - Sonra permutasyon yarıları yer değiştirir.

Feistel Cipher Yapısı

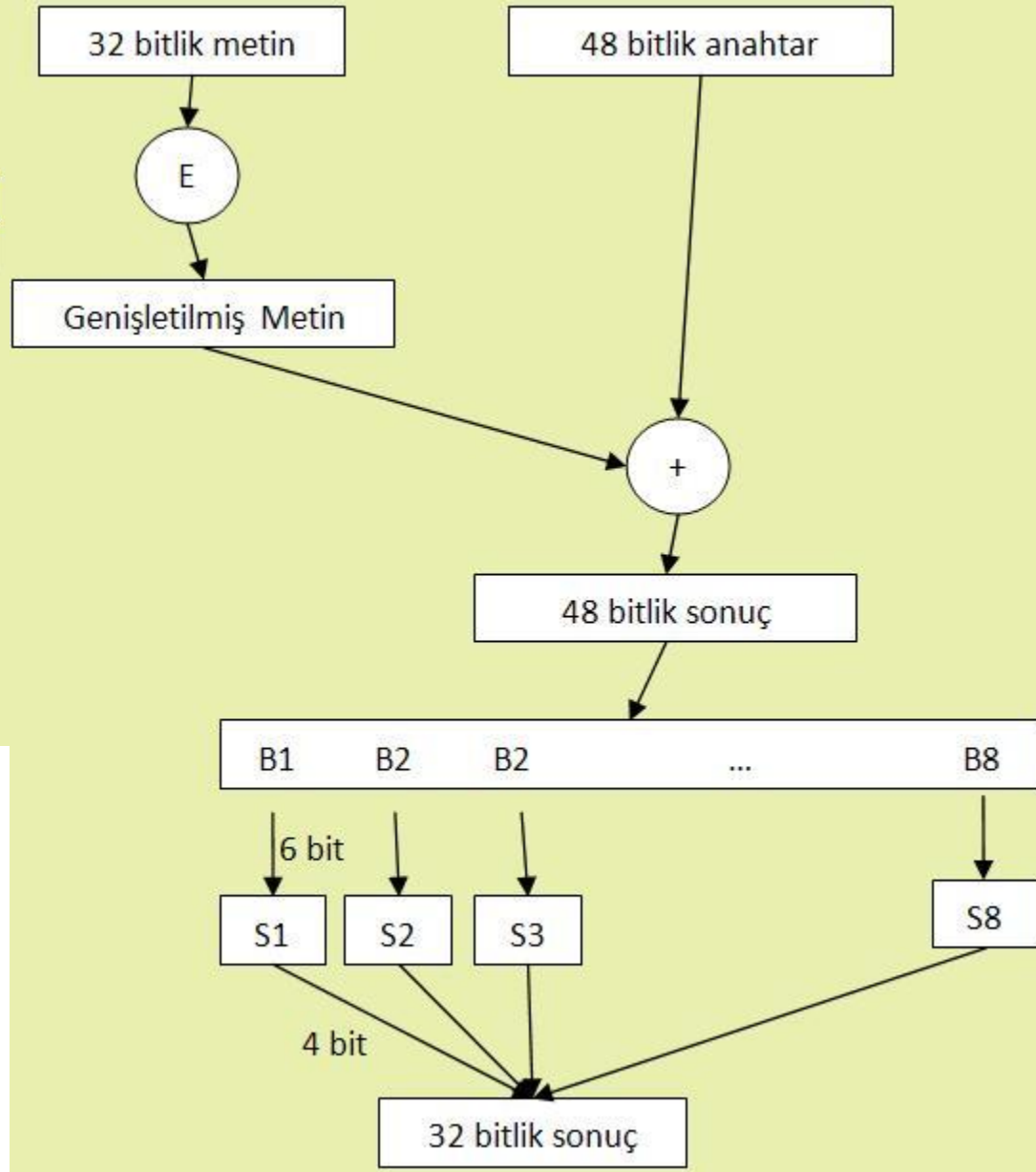
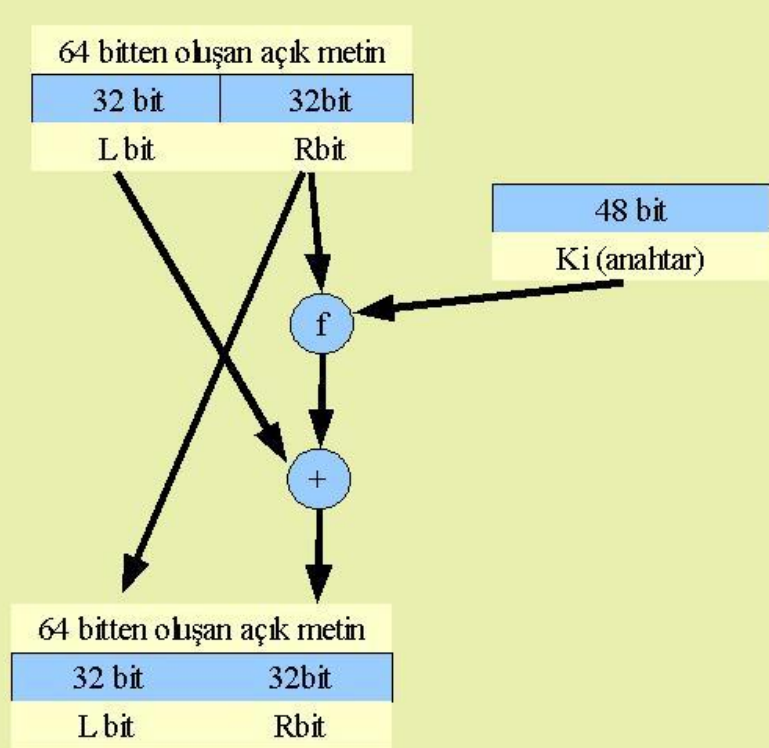


Feistel Cipher Tasarım Bileşenleri

- Blok boyutu
- Anahtar boyutu
- Döndürme sayısı
- Aly anahtar üretme fonksiyonu
- Döndürme fonksiyonu
- Hızlı şifreleme şifre çözme yazılımı

Data Encryption Standard (DES)

- Dünyada en yaygın kullanılan cipher
- Ulusal Standartlar Dairesi ([NBS](#) - National Bureau of Standards); 1973'te “ulusal bir standart olabilecek kriptografik bir algoritma” talebinde bulunmuştu. Bu talebe yönelik [IBM](#)'nin 1974'te sunduğu LUCIFER algoritması, Ulusal Güvenlik Ajansı'nın ([NSA](#) – National Security Agency) uyguladığı değişikliklerin ardından 1977'de DES (Data Encryption Standard) adıyla resmi bilgi şifreleme standardı olarak kabul edildi.
- 56 bit anahtar (key) kullanarak 64 bit data şifreleme
- 128 bit anahtar kullanarak 64 bit şifreleme (IBM)
- Güvenliği konusunda tartışmalar sürmektedir.



S ₅		Orta 4 bit															
		0000	0001	0010	0011	0100	0101	0110	0111	1000	1001	1010	1011	1100	1101	1110	1111
İlk ve son bitler	00	0010	1100	0100	0001	0111	1010	1011	0110	1000	0101	0011	1111	1101	0000	1110	1001
	01	1110	1011	0010	1100	0100	0111	1101	0001	0101	0000	1111	1010	0011	1001	1000	0110
	10	0100	0010	0001	1011	1010	1101	0111	1000	1111	1001	1100	0101	0110	0011	0000	1110
	11	1011	1000	1100	0111	0001	1110	0010	1101	0110	1111	0000	1001	1010	0100	0101	0011

Çoklu Şifreleme& DES

- clear a replacement for DES was needed
 - Teorik saldırılara karşı yetersiz
 - Kapsamlı anahtar arama saldırıları başarılı olmuştur.
- AES e alternatif olarak geliştirilmiştir
- Öncelikle çoklu şifreleme kullanıldı.
- Triple-DES
- Güçlü kriptografi dünyayı daha güvenli bir yer yapar.
- Strong cryptography makes the world a safer place

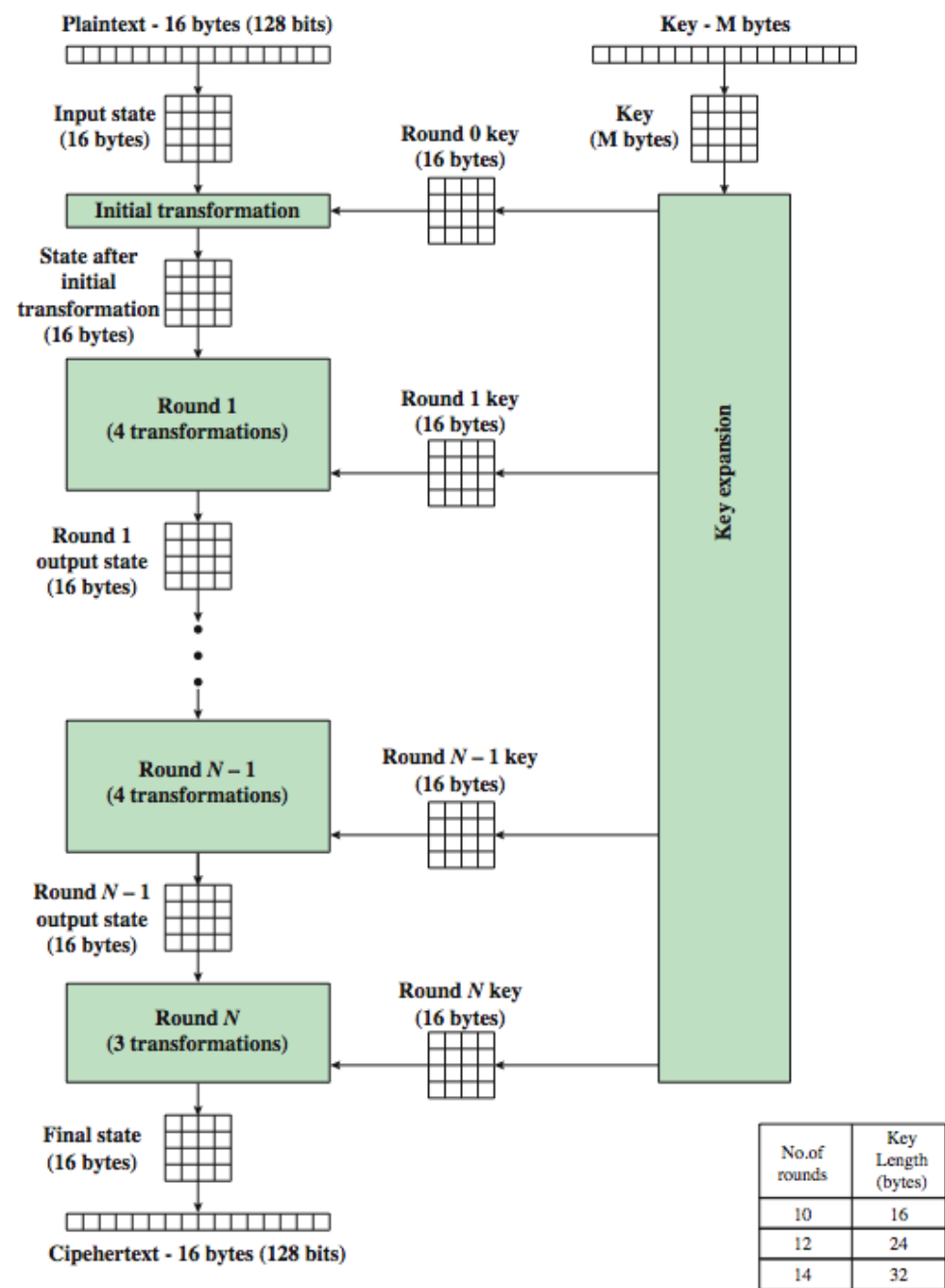
3-DES , 2- KEY

- 3 şifreleme ard arda kullanılır
 - 3 şifrelemede ayrı anahtar kullanılır
- Fakat 2 anahtarda kullanılabilir E-D-E fonkdiyonları
 - $C = E_{K1} (D_{K2} (E_{K1} (P)))$
 - $K1=K2$ tek DES
- ANSI X9.17 & ISO8732
- Pratik bir saldırı yoktur.
 - önerilen bazı pratik olmayan saldırılar, gelecekteki saldırıların temelini oluşturabilir

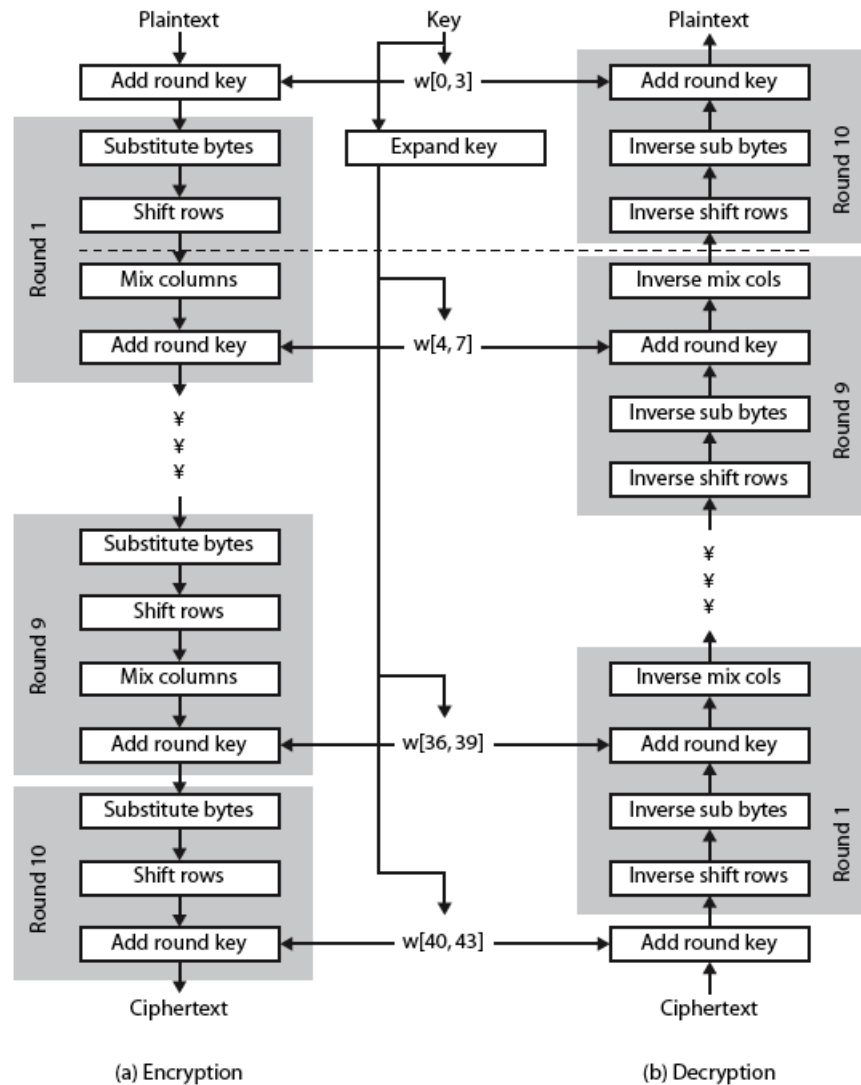
AES Cipher

- Rijmen-Daemen
- 128/192/256 bit anahtar, 128 bit veri
- feistel şifresi yerine yinelemeli
 - verileri 4 baytlık 4 sütun bloğu olarak işler
 - her turda tüm veri bloğu üzerinde çalışır
- Tasarım olarak
 - Saldırılara karşı dirençlidir
 - Bir çok CPU da hız ve kodlama etkilidir
 - Tasarımı basittir.

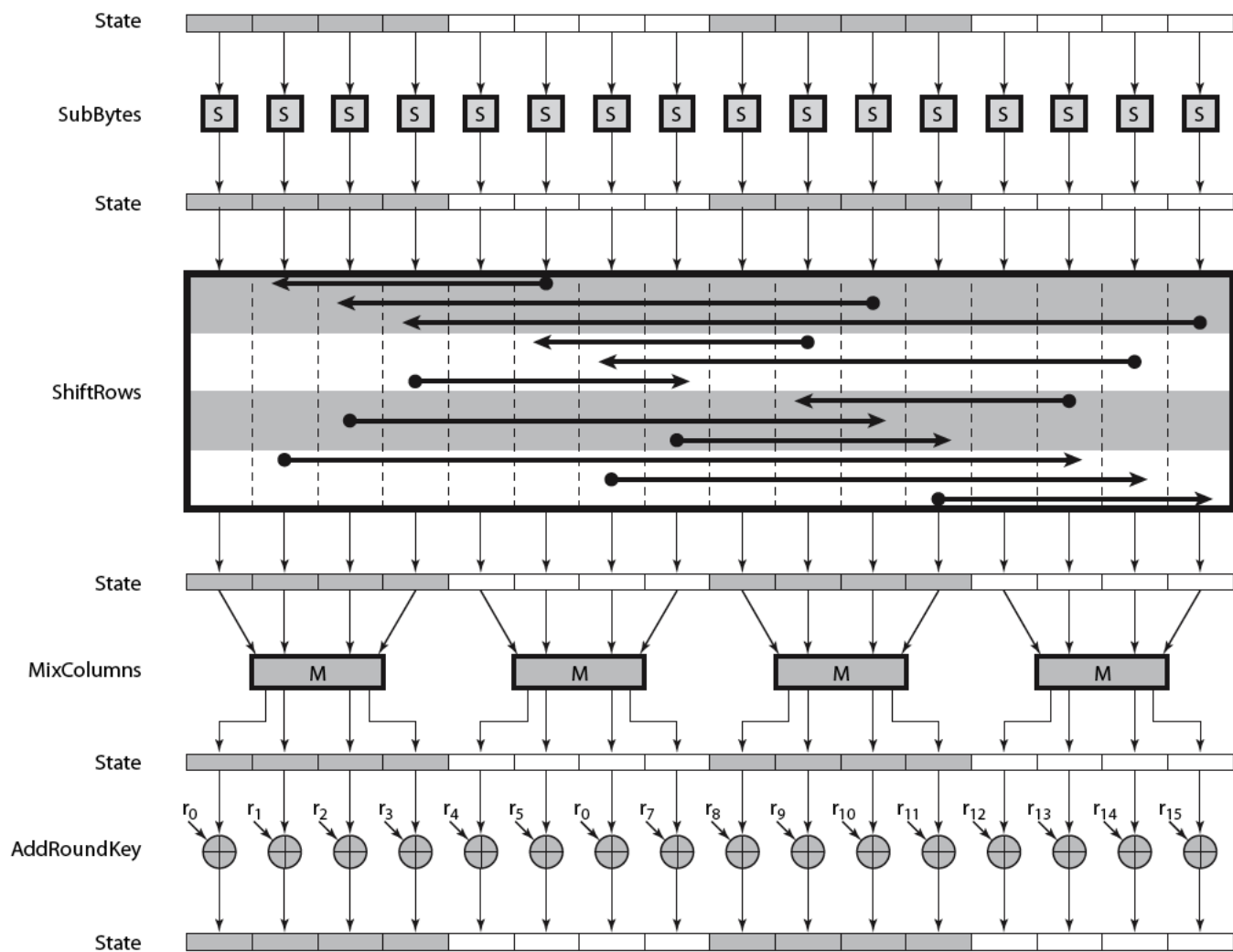
AES Şifreleme



AES Structure



AES Round



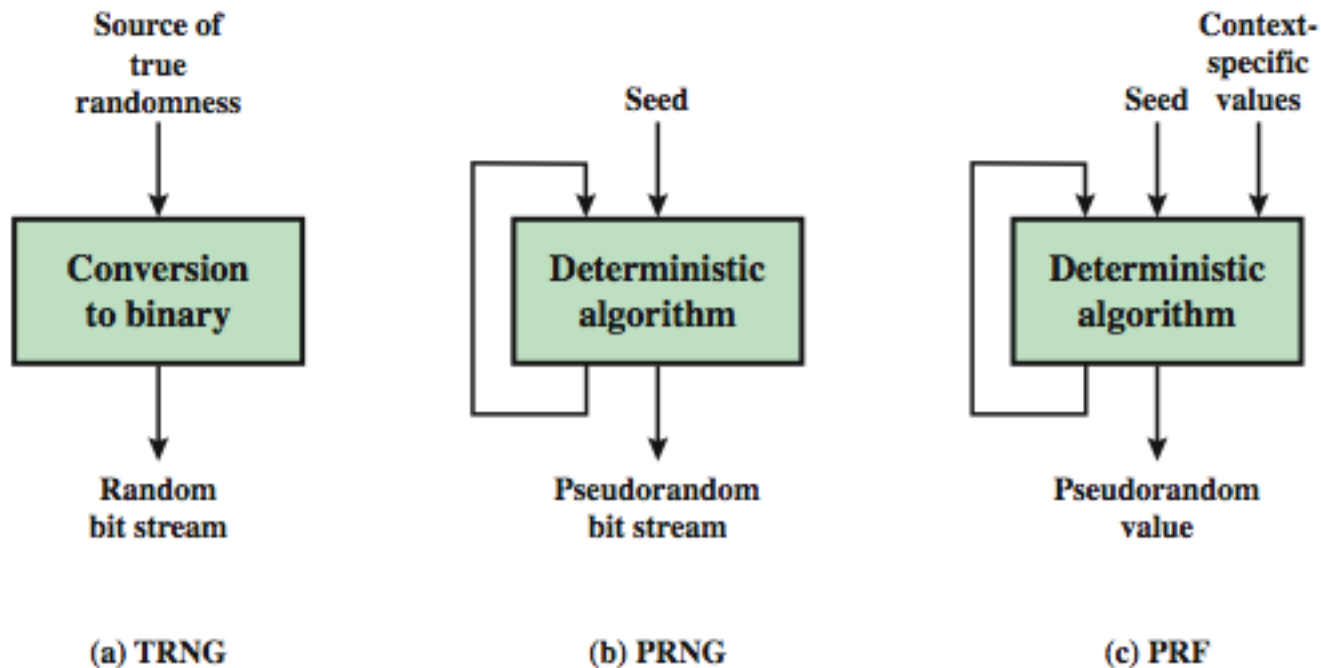
Rastgele Sayılar

- Kriptografide bir çok random sayı kullanılmaktadır.
 - tekrarlamayı önlemek için kimlik doğrulama protokollerinde
 - oturum anahtarları
 - genel anahtar üretimi
 - bir kerelik için key
- Bu değerler tüm durumlarda kritiktir
- istatistiksel olarak rasgele, tekdüze dağılım, bağımsız
- gelecekteki değerlerin önceki değerlerden tahmin edilemezliği
- Gerçek rastgele sayılar, oluşturulan rasgele sayılarla bu durumu sağlar

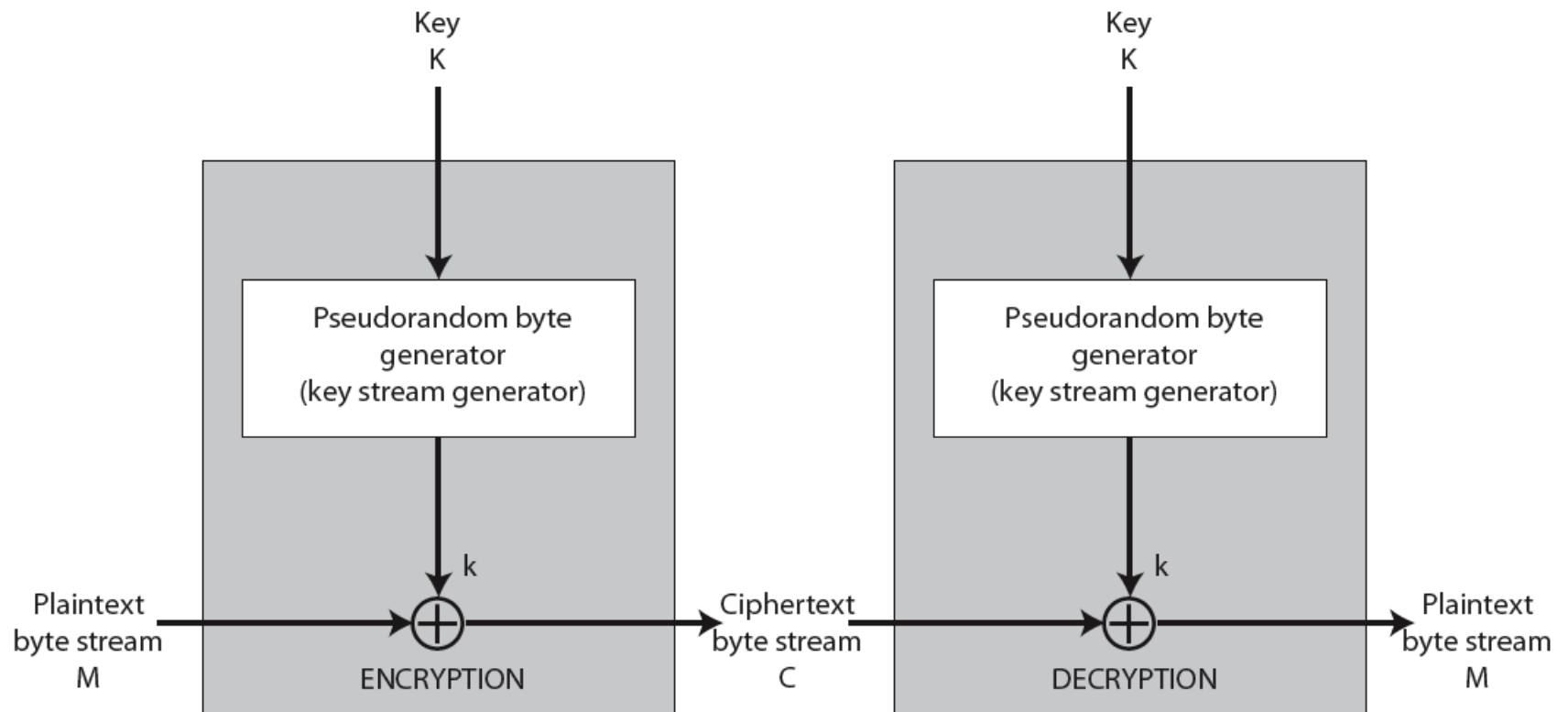
Pseudorandom Sayı Üretimi (PRNGs)

- “rastgele sayılar” oluşturmak için genellikle deterministik algoritmik teknikleri kullanır
- her ne kadar gerçekten rastgele değil
- “rastgelelik” ile ilgili birçok testi geçebilir

Rastgele & Pseudorandom Sayı Üretici



Stream Cipher Yapıları



Stream Cipher Özellikleri

- Şifreleme dizisi büyük bir zamana sahip olmalı, tekrarlanma süresi ne kadar uzun olursa, kriptanaliz yapılması daha zor olacaktır.
- Anahtar dizisi mümkün olduğunca yakın bir true rasgele sayı akışının özelliklerine yaklaşmalıdır, daha fazla rastgele görünen anahtar akışı, şifreli metin rastgeleliği, kriptanalizi daha zor hale getiriyor.
- Brute Force saldırılarına karşı korunmak için, anahtarın yeterince uzun olması gerekiyor. Blok şifreler için geçerli olan aynı hususlar burada geçerlidir. Bu nedenle, şu anki teknoloji ile, en az 128 bitlik bir anahtar uzunluğu istenmektedir.
- Uygun şekilde tasarlanmış bir sözde sayı üretici ile, bir akış şifresi, karşılaştırılabilir anahtar uzunluğuna sahip blok şifreleyici kadar güvenli olabilir. Bir akış şifresinin birincil avantajı, stream şifrelerinin neredeyse her zaman daha hızlı olması ve blok şifrelere göre çok daha az kod kullanmasıdır. Herhangi bir kriptografik olarak güçlü PRNG ile bir akış şifresi kurulabilir.

RC4

RC4, 1987 yılında Ron Rivest tarafından RSA Security için tasarlanan bir akış şifresidir.

- Bayt tabanlı işlemler ile değişken anahtar boyutlu bir akış şifreleyicidir.
- Algoritma, rasgele bir permütasyon kullanımına dayanmaktadır.
- SSL / TLS güvenli web protokolünde ve WEP & WPA kablosuz LAN güvenlik protokollerinde kullanılır.

RC4 Anahtar Planlama

- S dizisi başlangıcı: 0..255
- Anahtarı kullanmak için karıştırır.
- S şifrenin iç durumunu oluşturur.

```
for i = 0 to 255 do
```

```
    S[i] = i
```

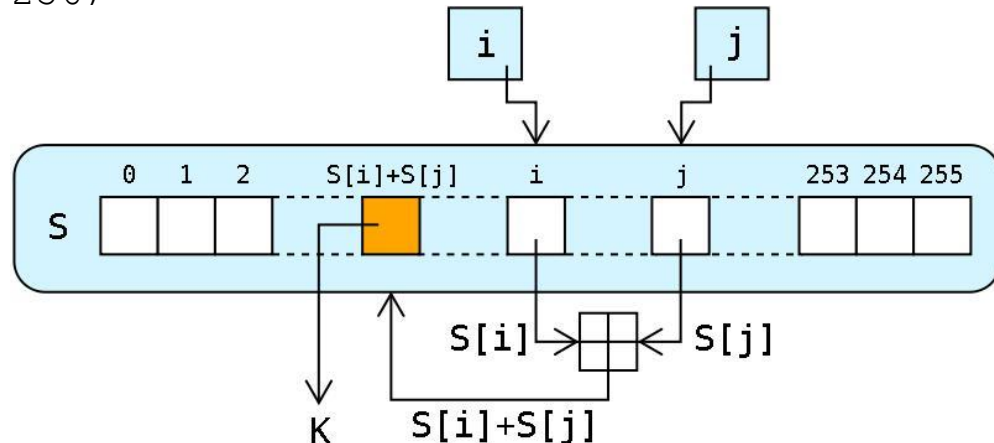
```
    T[i] = K[i mod keylen])
```

```
j = 0
```

```
for i = 0 to 255 do
```

```
    j = (j + S[i] + T[i]) (mod 256)
```

```
    swap (S[i], S[j])
```



RC4 Encryption

- encryption continues shuffling array values
- sum of shuffled pair selects "stream key" value from permutation
- XOR $S[t]$ with next byte of message to en/decrypt

$i = j = 0$

for each message byte M_i

$i = (i + 1) \pmod{256}$

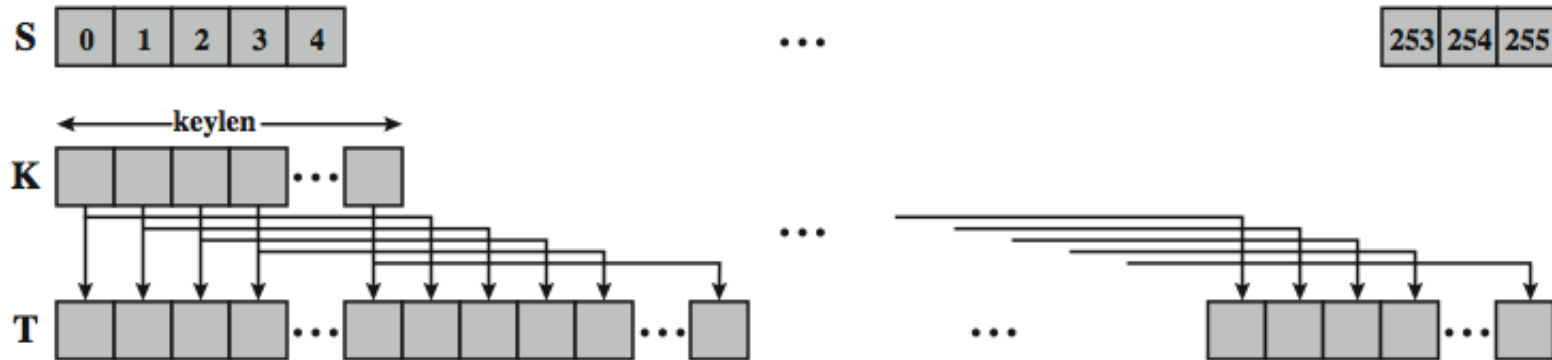
$j = (j + S[i]) \pmod{256}$

swap($S[i]$, $S[j]$)

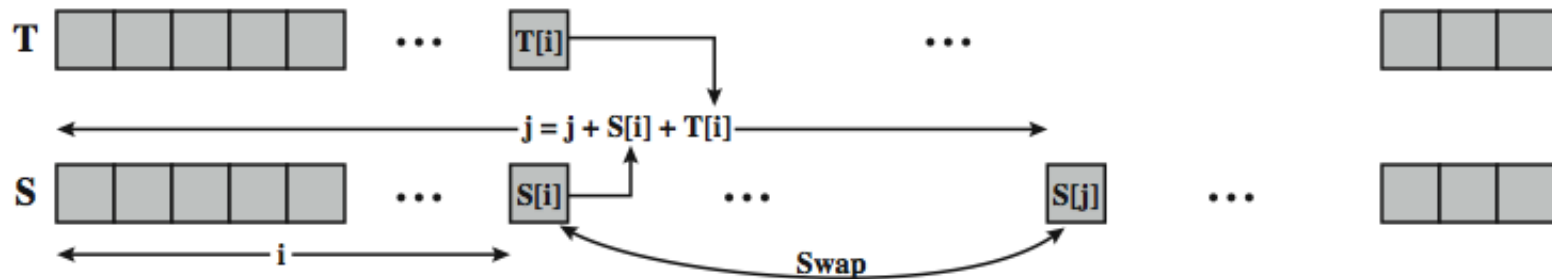
$t = (S[i] + S[j]) \pmod{256}$

$C_i = M_i \text{ XOR } S[t]$

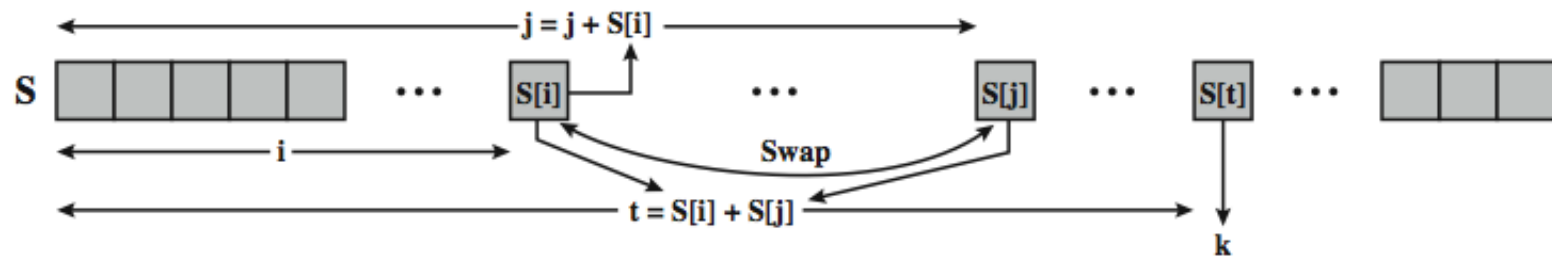
RC4 Yapısı



(a) Initial state of S and T



(b) Initial permutation of S



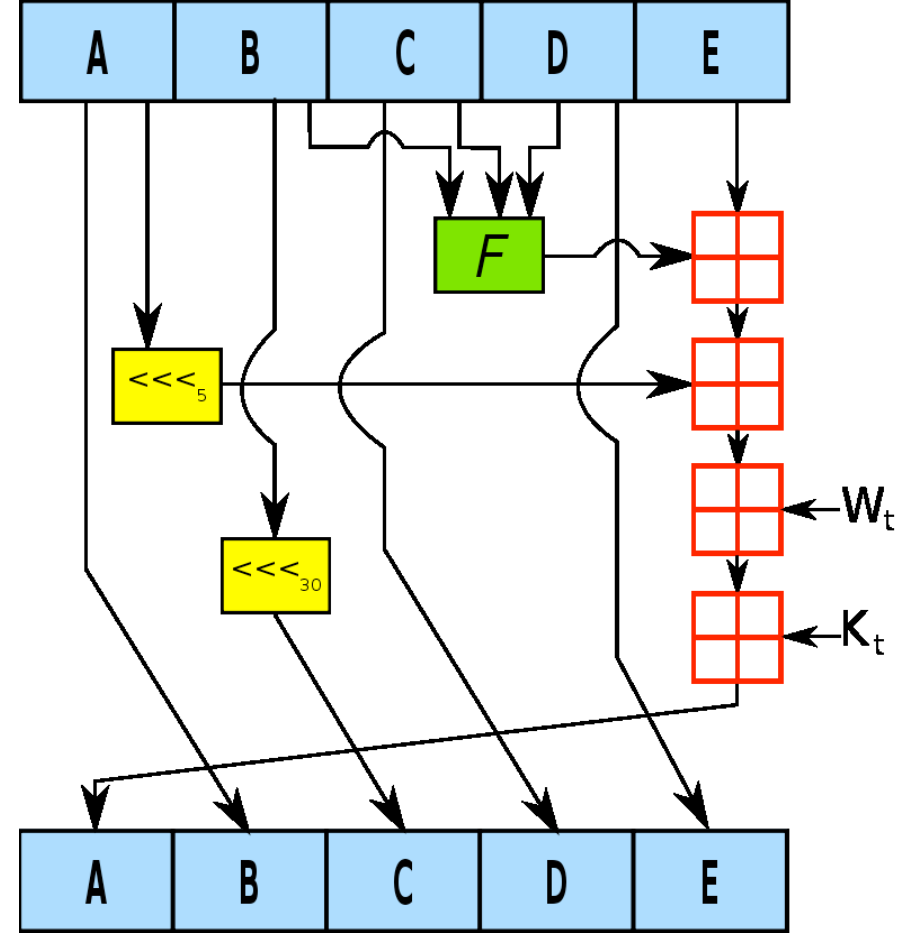
(c) Stream Generation

MD5

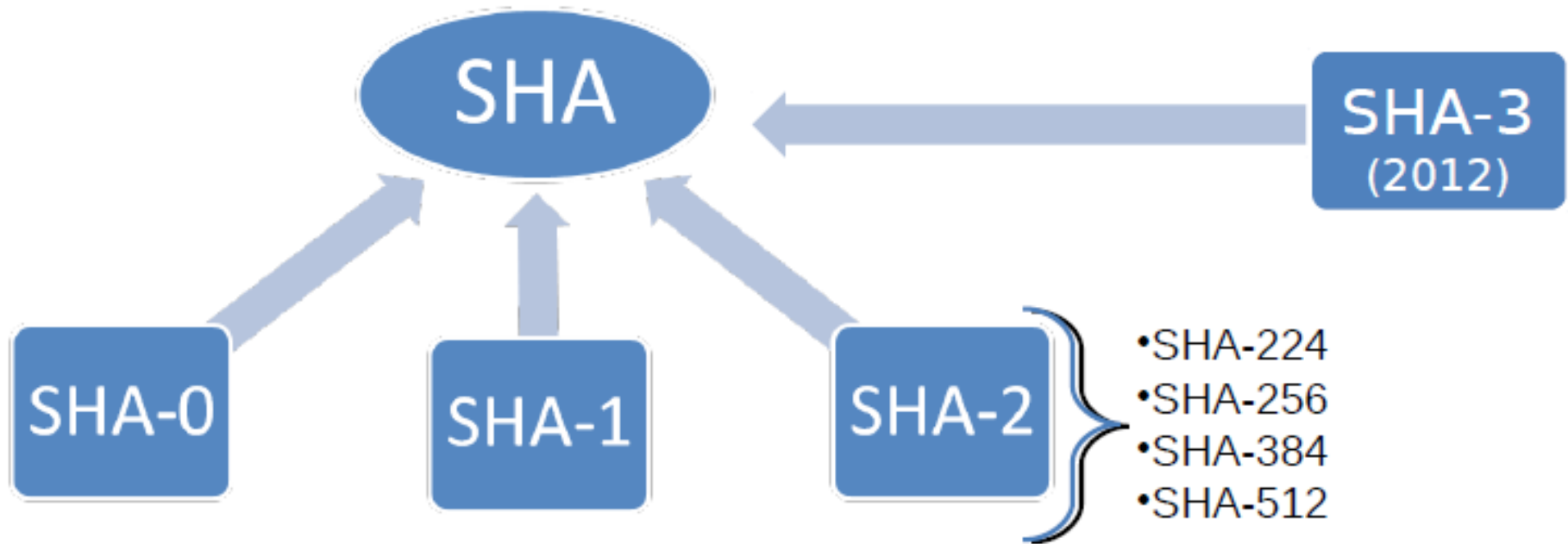
- MD5 (Message-Digest algorithm 5) Ron Rivest tarafından 1991 yılında geliştirilmiş bir tek yönlü şifreleme algoritmasıdır, veri bütünlüğünü test etmek için kullanılan, bir şifreleme algoritmasıdır. Bu algoritma girdinin büyüklüğünden bağımsız olarak 128-bit'lik bir çıktı üretir ve girdideki en ufak bir bit değişikliği bile çıktının tamamen değişmesine sebep olur.
- MD5'in en çok kullandığı yerlerden biri, bir verinin (dosyanın) doğru transfer edilip edilmediği veya değiştirilip değiştirilmediğinin kontrol edilmesidir.

SHA-1 Şifreleme

- SHA (Secure Hash Algorithm – Güvenli Özetleme Algoritması), Amerika'nın ulusal güvenlik kurumu olan NSA tarafından tasarlanmıştır.
- SHA-1, uzunluğu en fazla 264 bit olan mesajları girdi olarak kullanır ve 160 bitlik mesaj özeti üretir. Bu işlem sırasında, ilk önce mesajı 512 bitlik bloklara ayırır ve gerekirse son bloğun uzunluğunu 512 bite tamamlar.
- SHA-1 çalışma prensibi olarak R. Rivest tarafından tasarlanan MD5 özet fonksiyonuna benzer. 160 bitlik mesaj özeti üreten SHA-1 çakışmalara karşı 80 bitlik güvenlik sağlar.



SHA Çeşitleri

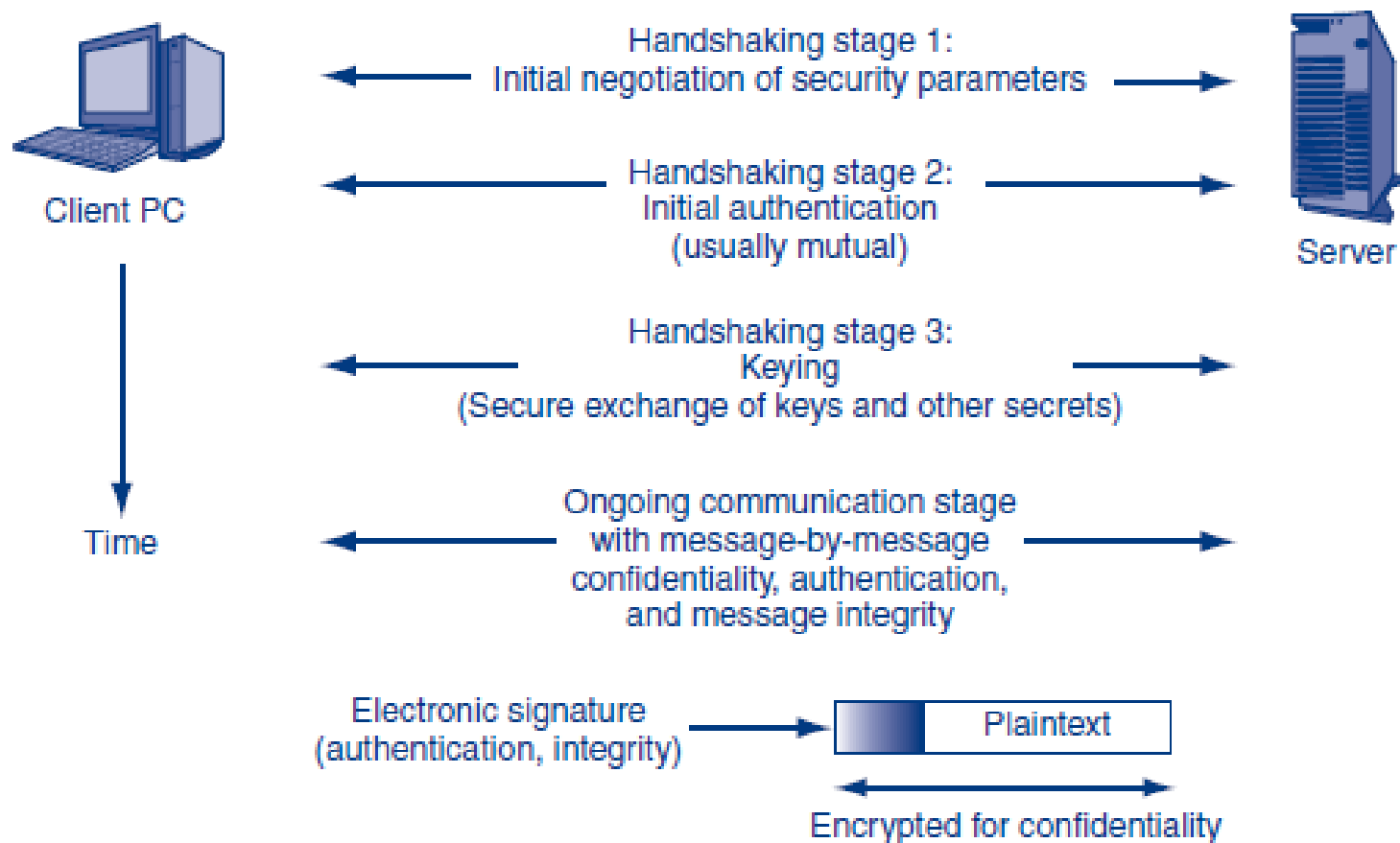


Kriptografik Sistem Standartları

Kriptografik Sistemler

- Gizlilik kriptografinin genel amacıdır.
- Kriptografi askeri ve iş amaçlı organizasyonlarda mesaj değişimindeki bir çok kriptografik korumlardan birisi şifreleme olarak bilinmektedir.
- Uygulamada bir kriptografik sistem tarafından sağlanan bu korumalar kriptografik bir paketler kümesidir.
- Popüler kriptografik sistem standartları
- SSL –Secure Sockets Layer
- TLS – Transport Layer Security
- IPSec

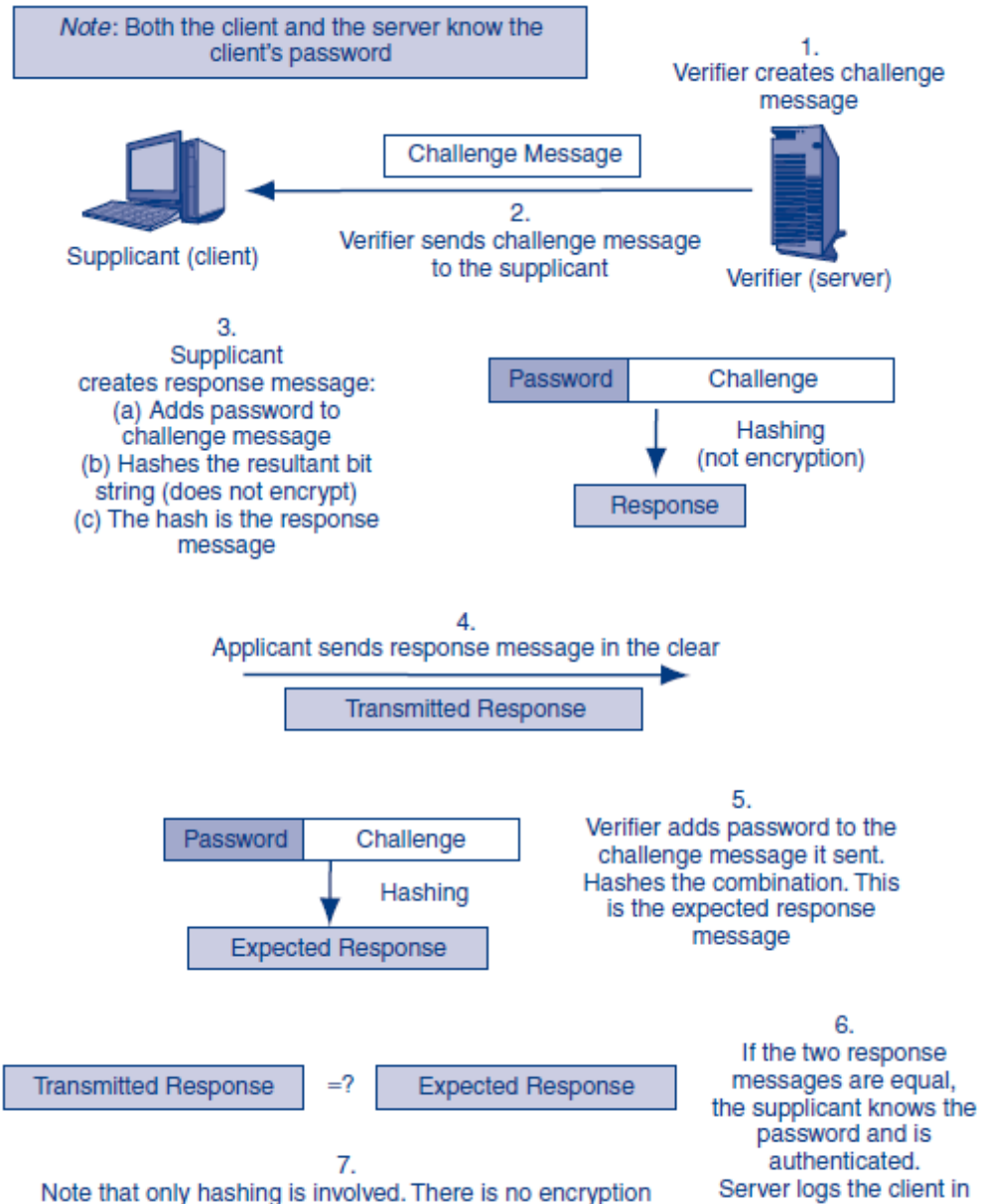
Kriptografik Sistem Adımları



SSL/TLS Cipher Suite

Cipher Suite	Key Negotiation	Digital Signature Method	Symmetric Key Encryption Method	Hashing Method for HMAC	Strength
NULL_WITH_NULL_NULL	None	None	None	None	None
RSA_EXPORT_WITH_RC4_40_MD5	RSA export strength (40 bits)	RSA export strength (40 bits)	RC4 (40-bit key)	MD5	Weak
RSA_WITH_DES_CBC_SHA	RSA	RSA	DES_CBC	SHA-1	Stronger but not very strong
DH_DSS_WITH_3DES_EDE_CBC_SHA	Diffie–Hellman	Digital signature standard	3DES_EDE_CBC	SHA-1	Strong
RSA_WITH_AES_256_CBC_SHA256	RSA	RSA	AES 256 bits	SHA-256	Very strong

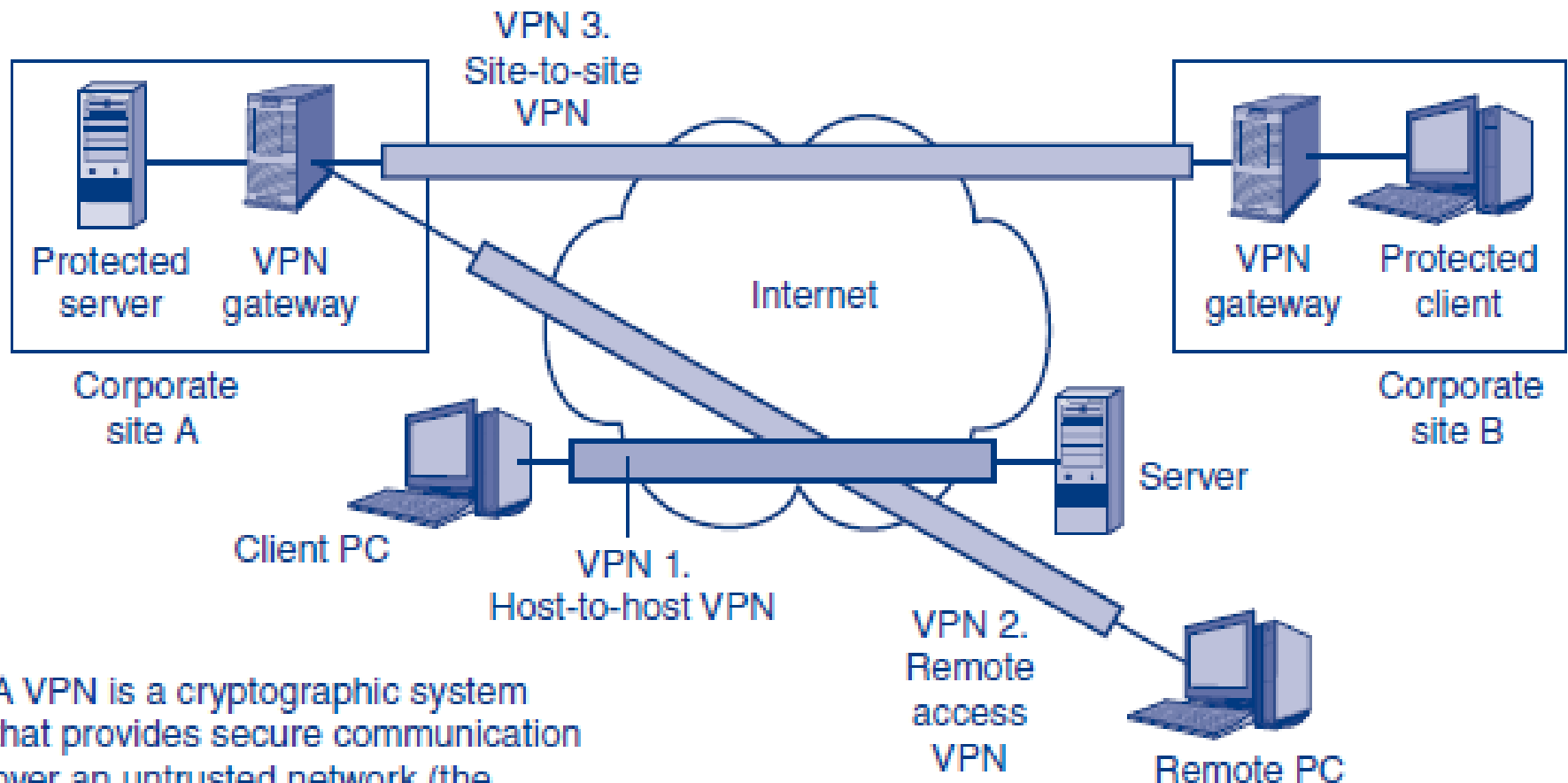
Başlangıç Kimlik Doğrulaması (MS-CHAP)



VPN (Virtual Private Network)

- Kriptografik sistemler genellikle güvenilmeyen ağlar üzerinde kullanılır.
- Güvenilmeyen bir ağ (İnternet, Wireless LAN vb.) üzerinde güvenli iletişim için kullanılan kriptografik bir sistemde VPN (sanal Özel Ağlar) dır.
- Neden VPN?
 - Neden güvenilmeyen ağlar üzerinde iletim tercih edilmiyor?
 - İnternet VPNlerinin durumlarıda, cevap basit ekonomilerdir: İnternet iletimleri Frame relay gibi ticari geniş alan ağlarına göre çok daha pahalıdır. İnternet devasa boyuttaki büyük ölçekli ekonomileri beraberinde getiriyor.
 - Özellikle güvenlik açıklarından dolayı eleştirilmesine rağmen Wirelelss LAN üzerindeki VPNler, hareketlilik faydalarından dolayı bir şirkette kolaylıkla ağa dahil olmayı sağlamaktadır

VPN Türleri



A VPN is a cryptographic system that provides secure communication over an untrusted network (the Internet, a wireless LAN, etc.)